Technical Product Requirements

Foundational Platform Service v2.0

Version: 1.0 | **Author:** John Sawyer | **Status:** Draft for Review

Table of Contents

1. Problem Statement
2. Outcomes
3. Target Users and Personas
4. Success Metrics and SLA Targets
5. Scope Boundaries and Key Assumptions
6. Risks and Mitigations
7. Appendix: Glossary

1. Problem Statement

Current State

Defense and government programs require secure, compliant infrastructure to deploy mission-critical applications. Current approaches face significant challenges:

- **ATO Timelines:** Traditional Authority to Operate (ATO) processes take 12–18 months, creating unacceptable delays for mission-critical capabilities
- **Multi-Cloud Fragmentation:** Each cloud provider requires separate infrastructure code, increasing maintenance burden and drift risk
- **Edge/D-DIL Gaps:** Disconnected, denied, intermittent, and limited (D/DIL) environments lack consistent tooling with connected cloud environments
- **Zero Trust Adoption:** Most existing platforms use perimeter-based security rather than identity-centric Zero Trust Architecture
- **Compliance Burden:** Manual evidence collection and documentation consumes engineering resources that should focus on mission capabilities

Impact

- Mission teams wait months before deploying capabilities to production
- Security posture inconsistencies across cloud and edge environments
- Duplicated effort maintaining separate infrastructure stacks per cloud
- Compliance drift between ATO checkpoints creates risk exposure

2. Outcomes

Goals

PRIORITY	GOAL	SUCCESS CRITERIA
P0	Portability	Single IaC codebase deploys to AWS GovCloud, Azure Government, and air-gapped K3s with <10% cloud-specific code
P0	Zero Trust Architecture	100% workload-to-workload communication uses mTLS with SPIFFE identity; no implicit trust
P0	ATO Acceleration	Time-to-ATO reduced from 12–18 months to 4–8 weeks using pre-approved components and automated evidence
P1	D/DIL Edge Support	Platform operates in fully disconnected mode for 30+ days with store-and-forward sync
P1	Continuous Monitoring	Configuration drift detected within 15 minutes; auto-remediation for 80% of drift scenarios
P2	Multi-Tenant Isolation	Cryptographic separation between tenants; no lateral movement possible between tenant namespaces

Non-Goals

EXCLUDED	RATIONALE
Application development frameworks	Focus on infrastructure substrate only; app teams choose their frameworks
Data analytics/ML platforms	Mission-specific; handled by tenant applications
GCP Assured Workloads	Limited DoD adoption; prioritize AWS/Azure for initial release
Cross-domain solution (CDS) hardware	Platform provides CDS integration API; CDS hardware is mission-specific

3. Target Users and Personas

Platform Engineer

Deploys and maintains the foundational platform across environments

PRIMARY

NEEDS

- One-command environment provisioning
- Consistent tooling across cloud and edge
- Clear upgrade paths and rollback procedures
- Observability into platform health

POSSIBLE PAIN POINTS

- Managing cloud-specific Terraform for each provider
- Manual security hardening checklists
- Debugging network connectivity in air-gapped environments

SUCCESS CRITERIA

- Time-to-environment (TTE) < 90 minutes
- Single `make deploy-<env>` command provisions complete environment
- Platform drift detected and alerted automatically

Accreditor / ISSO

Authorizes systems for operation; validates security controls

KEY STAKEHOLDER

NEEDS

- Clear control inheritance documentation
- Automated evidence collection
- Continuous compliance visibility
- Audit trail for all privileged actions

POSSIBLE PAIN POINTS

- Manual evidence gathering takes weeks
- Point-in-time snapshots miss configuration drift
- Difficulty mapping infrastructure to NIST 800-53 controls

SUCCESS CRITERIA

- 80% of FedRAMP High controls satisfied at platform layer
- Evidence bundles generated on-demand in < 1 hour
- Continuous compliance dashboard with control status

Security Team

Secures workloads through threat modeling, AppSec, and penetration testing

SECURITY

NEEDS

- Comprehensive threat modeling capabilities
- Vulnerability scanning and management integration
- Penetration testing access and tooling
- Security event correlation and incident response

POSSIBLE PAIN POINTS

- Limited visibility into workload security posture
- Manual vulnerability assessment processes
- Difficulty correlating security events across environments
- Lack of standardized security baselines

SUCCESS CRITERIA

- Automated SAST/DAST integration in CI/CD pipeline
- Real-time security posture dashboard across all environments
- Threat model artifacts generated for each tenant workload
- Mean-time-to detect (MTTD) security incidents < 5 minutes

Developer

Deploys mission applications on the platform

CONSUMER

NEEDS

- Simple onboarding process
- Self-service namespace provisioning
- Clear service mesh integration patterns
- Access to platform services (secrets, logging, registry)

POSSIBLE PAIN POINTS

- Complex security requirements slow development
- Inconsistent behavior between environments
- Limited visibility into platform capabilities

SUCCESS CRITERIA

- Tenant namespace provisioned < 15 minutes after request
- Identical developer experience across cloud and edge
- Clear documentation for platform service consumption

4. Success Metrics and SLA Targets

Operational Metrics

METRIC	TARGET	MEASUREMENT
Time-to-Environment (TTE)	≤ 90 minutes	From `terraform apply` to healthy EKS cluster
Time-to-Tenant	≤ 15 minutes	From tenant request to provisioned namespace
Platform Availability	99.9%	Control plane uptime (excludes scheduled maintenance)
Drift Detection MTTR	≤ 15 minutes	Time from drift occurrence to alert
Drift Remediation MTTR	≤ 4 hours	Time from alert to remediated state

Security Metrics

METRIC	TARGET	MEASUREMENT
Control Coverage	≥ 80%	FedRAMP High controls satisfied at platform layer
mTLS Adoption	100%	Workload traffic using SPIFFE-based mTLS
Vulnerability SLA (Critical)	≤ 24 hours	Time to remediate critical vulnerabilities
Vulnerability SLA (High)	≤ 7 days	Time to remediate high vulnerabilities
Secrets Rotation	Automatic	90-day rotation for service credentials

Cost Guardrails

Cost management is implemented through cloud-native budget controls and automated alerting to prevent overspend and ensure fiscal accountability.

Cost Control Implementation

CAPABILITY	AWS GOVCLOUD	AZURE GOVERNMENT
Budget Alerts	AWS Budgets with SNS notifications at 50%, 80%, 100% thresholds	Azure Budgets with Action Groups for email/webhook alerts
Anomaly Detection	AWS Cost Anomaly Detection with daily monitoring	Azure Cost Management anomaly alerts
Cost Allocation	Cost allocation tags (CostCenter, Environment, Owner)	Azure tags + Cost Management scopes per subscription
Spend Visibility	AWS Cost Explorer with custom reports	Azure Cost Analysis with custom views and exports
Automated Actions	Lambda functions triggered by budget alerts to scale down non-critical resources	Azure Automation runbooks for resource scaling/shutdown
Reserved Capacity	Savings Plans and Reserved Instances for predictable workloads	Azure Reservations for VMs, storage, and databases

5. Scope Boundaries and Key Assumptions

In Scope

- **Infrastructure Layer:** VPC/VNet, subnets, NAT, DNS, Transit Gateway
- **Compute Layer:** EKS/AKS/K3s clusters with managed node groups
- **Security Layer:** KMS, secrets management, WAF, network firewall
- **Identity Layer:** SPIFFE/SPIRE, workload identity federation
- **Observability Layer:** Logging, metrics, tracing, SIEM integration
- **Policy Layer:** OPA/Gatekeeper admission control, Conftest validation

Out of Scope

- Application workloads and business logic
- Data pipeline tooling (Airflow, Spark, etc.)
- ML/AI training infrastructure
- Physical security controls
- Personnel security (background checks, clearances)

Key Assumptions

ASSUMPTION	IMPACT IF INVALID
AWS GovCloud services match commercial parity for EKS, KMS, GuardDuty	May require service substitution or custom implementation
Azure Government provides Workload Identity and Defender for AKS	Azure module complexity increases significantly
Air-gapped environments have physical HSM capability	Software-based key management reduces IL6 eligibility
SPIFFE/SPIRE operates reliably in intermittent connectivity	Identity may fail during network partitions
Zarf packages can be transferred via approved media	Delays in air-gap updates if approval process changes

CSP Service Availability (IL4/IL5 Regions)

SERVICE	AWS GOVCLOUD	AZURE GOVERNMENT	NOTES
Managed Kubernetes	EKS	AKS	Both IL5 authorized
Key Management	KMS + CloudHSM	Key Vault + HSM	FIPS 140-2 L3
Container Registry	ECR	ACR	Private endpoints required
Secrets Manager	Secrets Manager	Key Vault	Rotation automation
Threat Detection	GuardDuty	Defender	Kills audit log integration
Config Management	AWS Config	Policy	Drift detection

6. Risks and Mitigations

Technical Risks

RISK	LIKELIHOOD	IMPACT	MITIGATION
Service Parity Gaps	Medium	High	Abstraction layer isolates cloud-specific differences; fallback to self-managed services
SPIFFE/SPIRE Complexity	Medium	Medium	Phased rollout; start with cloud-native identity, migrate to SPIFFE
Air-Gap Sync Delays	Medium	Medium	Automated package generation; streamlined approval workflow
Policy Engine Performance	Low	Medium	OPA bundle optimization; policy caching; admission webhook tuning

Operational Risks

RISK	LIKELIHOOD	IMPACT	MITIGATION
Edge Patching Delays	High	High	Vulnerability prioritization, offline CVE database, pre-approved patch packages
Key Rotation Failures	Low	Critical	Dual-key architecture; automated rotation testing; break-glass procedures
Tenant Resource Exhaustion	Medium	Medium	Resource quotas; burst limits; namespace isolation

Compliance Risks

RISK	LIKELIHOOD	IMPACT	MITIGATION
Control Drift	Medium	High	Continuous monitoring, automated remediation, drift alerts
Evidence Staleness	Medium	Medium	On-demand evidence generation; cryptographic timestamps
CDS Integration Delays	High	Medium	Abstract CDS interface; parallel development with CDS vendor

A. Appendix: Glossary

ATO	Authority to Operate - formal approval to operate a system
CATO	Continuous Authority to Operate - ongoing authorization with real-time monitoring
CDS	Cross-Domain Solution - guards for data transfer between security domains
D/DIL	Denied, Disconnected, Intermittent, Limited - degraded network conditions
IL4/IL5	Impact Level 4/5 - DoD data classification levels
SPIFFE	Secure Production Identity Framework for Everyone
SPIRE	SPIFFE Runtime Environment
TTE	Time-to-Environment - provisioning duration
ZTA	Zero Trust Architecture